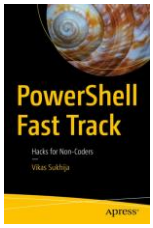
Week 3 Cyber Threat Intelligence (CTI)

By the end of the tutorial you will have:

- Setup and verified virtual machines for vulnerability scanning:
  - Att (Kali) VM including Nessus
  - Metasploitable2 (Ms2) VM
- Used CTI to understand malware such as Deep Panda and test your systems' defenses against a predicted attack
- Created PowerShell scripts with functions, loops and conditionals
- Started Quiz 1 PowerShell

Readings

These reading are available on the unit website.



- Chapter 1 of (Sukhija 2021). PowerShell Basics. This reading which provides an introduction to PowerShell arrays, conditionals (if), loops (for, foreach, foreach-object) and functions. This optional reading complements the exercises in this tutorial. Please read this Chapter if you struggle with this tutorial.
- Chapter 3 of (Thompson 2020): Threat Intelligence. This reading provides an introduction to CTI including the steps in the ATT&CK lifecycle, a standard for communicating CTI (STIX), the pyramid of pain, evaluating CTI, ATT&CK techniques used by Deep Panda and other sources of CTI.

Nessus for use next week

Download the Att (Kali) virtual machine image and import it into Oracle Virtualbox for use next week. The virtual machine has Nessus installed. We will use Nessus next week to perform a vulnerability analysis on Ms2. Nessus needs to be setup prior to use:

- Start your Kali virtual machine.
- Browse to Nessus, e.g. using port forwarding on NIC1 https://localhost:34834
  - Alternatively, using the host only network on NIC2: https://172.16.1.34:8834
- Select Nessus Essentials
- Register for an account with Tenable. Keep a record of your activation key
- Create an admin account and remember your username and password
- Expect Nessus to take at least 20 minutes to download and compile plugins inside the Kali virtual machine

MS2 Virtual Machine for use next week

Download the MS2 virtual machine image and import it into Oracle Virtualbox for use next week. Verify your Ms2 machine by browsing to http://localhost:35080. Please stop your MS2 virtual machine whenever you are not using it as it has deliberate security issues.

MITRE ATT&CK Categories

What is the purpose of MITRE ATT&CK and what is the name of the category that involves moving around a victim's environment?

CRICOS Code: 00219C | RTO Code: 40939

BE WHAT YOU WANT TO BE
cqu.edu.au

Categorise a MITRE ATT&CK Tactic
There is an attacker tactic that involves configuring the Android OS to run some code when an event occurs. For example, FakeSpy registers code to execute when the BOOT_COMPLETED event occurs. What category does this tactic belong to?

Predicting ATT&CK Techniques with MITRE
Imagine you are Optus. Use MITRE ATT&CK Groups to determine which Threat Actors (TAs) might target you?

Based on your previous answer, what techniques should Optus prioritise defending against?

Defending An ATT&CK Technique with CAPEC
Assume a Threat Actor (TA) plans to use T1083 *File and Directory Discovery* to identify a hidden API. First, use MITRE ATT&CK Techniques to give examples of software that might be used. Secondly, provide a command line that performs File and/or Directory Discovery assuming the TA has access to the system.

Use CAPEC CTI to give an example of how a weakness related to T1083 *File and Directory Discovery* might be exploited and an example of how to mitigate or reduce the impact.

Conditionals and Test if a Server is Operational
Output "UP" or "DOWN" depending on whether the CQUni webserver is operational.

Loops (for)
Create and output a string contain the numbers 11 to 20 on the one line.

Loops (foreach or foreach-object)
Test the last 3 hops along your route to www.cqu.edu.au to see if each computer has an operational webserver.

Loops (tricky)
For each file in the current directory that can be written to, output the file length. Hint: the PsIsContainer attribute returns true for directories.

Sort and Unique
Output a unique, sorted list of file extensions for C:\Windows using the ToUpper() string function.

```
PS> …
.BAT
.BIN
…
```

Arrays (tricky)

For each extension .BAT, .BIN and .EXE how many files in C:\Windows have those extensions?

```
PS> foreach ($ext …
.BAT 8
.BIN 1
.EXE 14
```

Arrays (tricky)

How many files in C:\Windows have file extensions .BAT, .BIN, .EXE or .DLL?

Processes using a Port

List all processes that are accessing web servers using HTTPS. Also check which processes are using HTTP. HTTPS uses port 443. HTTP uses port 80. There is an OwningProcess property provided by `Get-NetTCPConnection`.

Registry File Extensions

Write a function that returns whether file extensions are visible. File extensions are visible if the registry key HideFileExt of HKCU:\Software\Microsoft\Windows\CurrentVersion\Explorer\Advanced is disabled, that is, if HideFileExt is 0.

CRICOS Provider Code: 00314B | RTO Code: 40939